ACTIVIDAD 02 ANÁLISIS DE SERVICIOS DE SEGURIDAD (X.800 Y RFC 4949)

Laura Ivon Montelongo Martínez - 177291

CNO V: Seguridad Informática
Mtro. Servando López Contreras

Introducción

La creciente incidencia de eventos que afectan la seguridad de la información ha generado la necesidad de contar con marcos formales que permitan analizar y documentar incidentes de manera técnica y estructurada. En este contexto, el análisis de incidentes de seguridad informática requiere no solo la identificación de fallas, sino también el uso de estándares reconocidos que faciliten una comunicación clara y profesional.

El estándar ITU-T X.800 define los principales servicios de seguridad que deben protegerse en un sistema de información, permitiendo identificar de forma precisa cuáles han sido comprometidos durante un incidente. De manera complementaria, el RFC 4949 establece un marco terminológico que proporciona definiciones claras para describir amenazas, vulnerabilidades, ataques e impactos.

La aplicación conjunta de ambos marcos resulta altamente relevante en la seguridad informática actual, ya que permite un análisis integral de los incidentes, fortaleciendo la documentación técnica y la toma de decisiones orientadas a la prevención y mitigación de riesgos.

Ficha de análisis

Escenario 01.

En múltiples incidentes atribuidos al grupo LockBit, organizaciones públicas y privadas han sufrido el cifrado masivo de servidores tras un acceso inicial no autorizado. Antes de ejecutar el ransomware, los atacantes exfiltraron información sensible y posteriormente amenazaron con su publicación, evidenciando un compromiso simultáneo de la confidencialidad, la integridad y la disponibilidad. Desde el enfoque del RFC 4949, el incidente se clasifica como un multi-stage attack con data breach y availability attack, donde la indisponibilidad del sistema es solo una fase final del daño. La ausencia de respaldos inmutables y de detección temprana permitió que el impacto fuera total

Elemento	Respuesta
Servicios X.800 comprometidos.	Autenticación, Control de Acceso, Confidencialidad de Datos e Integridad de Datos, Disponibilidad
Definición(es) aplicable(s) RFC 4949.	• Access control: Proceso mediante el cual el uso de los recursos del sistema se regula de acuerdo con una política de seguridad y solo lo permiten las entidades autorizadas (usuarios, programas, procesos u otros sistemas) de acuerdo con dicha política. • Availability: La propiedad de un sistema o un recurso del sistema de ser accesible, utilizable u operativo bajo demanda. • Attack: Un acto intencional mediante el cual una entidad.intenta evadir los servicios de seguridad y violar la política de seguridad de un sistema. • Data compromise: Un incidente de seguridad en el que la información queda expuesta a un posible acceso no autorizado, de modo que podría haberse producido una divulgación, alteración o uso no autorizado de la información.
Tipo de amenaza	Externa (grupo criminal organizado).
Vector de ataque	Acceso inicial no autorizado seguido de movimientos laterales, exfiltración de datos y despliegue de ransomware.

Impacto técnico / operativo.	Indisponibilidad total de los sistemas, pérdida de información crítica y riesgo legal y reputacional derivado de la posible publicación de datos sensibles.
Medida de control recomendada.	Monitoreo y detección temprana de actividades anómalas, controles estrictos de acceso y planes de respuesta a incidentes.

Escenario 02.

En diversos casos documentados, bases de datos completas quedaron accesibles públicamente debido a errores de configuración en servicios de almacenamiento en la nube. No existió una explotación técnica sofisticada, sino una falla en el control de acceso, lo que derivó directamente en la pérdida de confidencialidad de los datos. El RFC 4949 describe este tipo de incidentes como misconfiguration y exposure, subrayando que la amenaza no siempre implica malware o intrusión activa. El impacto suele ser legal y reputacional, aun cuando no se pueda demostrar acceso malicioso.

Elemento	Respuesta
Servicios X.800 comprometidos.	Confidencialidad de Datos, Integridad de Datos y No Repudio.
Definición(es) aplicable(s) RFC 4949.	• Access control: Proceso mediante el cual el uso de los recursos del sistema se regula de acuerdo con una política de seguridad y solo lo permiten las entidades autorizadas (usuarios, programas, procesos u otros sistemas) de acuerdo con dicha política. • Exposure: Un tipo de acción de amenaza mediante la cual se divulgan datos confidenciales directamente a una entidad no autorizada.
Tipo de amenaza	Interna (Porque se origina en la administración interna de los sistemas).
Vector de ataque	Configuración incorrecta de permisos en servicios de almacenamiento en la nube.
Impacto técnico / operativo.	Pérdida de confidencialidad de datos sensibles, posibles sanciones legales y afectación a la reputación de la organización.
Medida de control recomendada.	Aplicar políticas de hardening en servicios de almacenamiento en la nube, evitando configuraciones abiertas al público salvo que sean estrictamente necesarias. revisión de privilegios.

Escenario 03.

Un proveedor legítimo de software fue comprometido y distribuyó una actualización que incluía código malicioso, afectando a cientos de organizaciones que confiaban en él. Este escenario refleja una violación grave de la integridad de los sistemas y, en muchos casos, de la confidencialidad, al permitir accesos no autorizados posteriores. El RFC 4949 lo identifica como supply chain attack, destacando el abuso de relaciones de confianza. El daño es particularmente crítico porque rompe el supuesto de legitimidad del software firmado.

Elemento	Respuesta
Servicios X.800 comprometidos.	Confidencialidad de Datos, Integridad de Datos, Autenticación
Definición(es) aplicable(s) RFC 4949.	• Integrity: Un cálculo que forma parte de un mecanismo para proporcionar un servicio de integridad de datos o un servicio de autenticación del origen de los datos.
Tipo de amenaza	Externa (Ejecutada por actores maliciosos que comprometieron al proveedor).
Vector de ataque	Distribución de actualización de software maliciosa distribuida por el proveedor.
Impacto técnico / operativo.	Interrupción operativa y riesgo de propagación lateral, Daño reputacional tanto para el proveedor como para las organizaciones afectadas, Pérdida de integridad en sistemas críticos, Exfiltración de datos sensibles.
Medida de control recomendada.	Usar sistemas de sandboxing o entornos de prueba antes de desplegar software en producción, No dar acceso amplio a software de terceros.

Escenario 04.

Mediante campañas de phishing, atacantes obtuvieron credenciales válidas y accedieron a sistemas corporativos durante meses sin levantar alertas. Aunque la autenticación funcionó técnicamente, el servicio de autenticación fue comprometido al basarse en credenciales robadas, afectando también el control de acceso. Según el RFC 4949, se trata de un credential compromise con authentication failure conceptual, no técnica. La falta de MFA y de monitoreo de comportamiento facilitó la persistencia del atacante.

Elemento	Respuesta
Servicios X.800 comprometidos.	Autenticación, Control de Acceso, Disponibilidad, Confidencialidad de Datos.
Definición(es) aplicable(s) RFC 4949.	• Authentication: Proceso de verificar una afirmación de que una entidad del sistema o un recurso del sistema tiene un valor de atributo determinado.
Tipo de amenaza	Externa (Originada por atacantes que ejecutaron campañas de phishing).
Vector de ataque	Campañas de phishing utilizadas para la obtención de credenciales válidas.
Impacto técnico / operativo.	Acceso persistente no autorizado, Exfiltración de información sensible, Impacto operativo y reputacional.
Medida de control recomendada.	Implementar MFA, Gestión de credenciales, ero Trust Architecture.

Escenario 05.

En ataques de ransomware avanzados, los atacantes eliminaron o cifraron los respaldos antes de afectar los sistemas productivos. Este hecho compromete directamente la disponibilidad y la integridad de la información, al impedir la recuperación. El RFC 4949 clasifica este comportamiento como data destruction y availability attack, evidenciando intención deliberada de maximizar el daño. La inexistencia de respaldos offline o inmutables convierte el incidente en catastrófico.

Elemento	Respuesta
Servicios X.800 comprometidos.	Confidencialidad de Datos, Disponibilidad, Integridad de datos.
Definición(es) aplicable(s) RFC 4949.	• Availability: La propiedad de un sistema o un recurso del sistema de ser accesible, utilizable u operativo bajo demanda. • Attack: Un acto intencional mediante el cual una entidad intenta evadir los servicios de seguridad y violar la política de seguridad de un sistema.
Tipo de amenaza	Externo (Actor malicioso con intención destructiva).
Vector de ataque	Acceso inicial no autorizado seguido de eliminación o cifrado de respaldos y despliegue de ransomware.
Impacto técnico / operativo.	Indisponibilidad de sistemas críticos, Pérdida de integridad de la información, Daño financiero.
Medida de control recomendada.	Segmentación de respaldos, Pruebas periódicas de restauración, MFA robusto, Plan de continuidad y recuperación ante desastres.

Escenario 06.

Un empleado con acceso legítimo extrajo bases de datos completas y las vendió a terceros, sin explotar vulnerabilidades técnicas. El servicio afectado fue principalmente la confidencialidad, junto con fallas en el control de acceso por exceso de privilegios. El RFC 4949 define este escenario como insider threat, destacando que el riesgo interno puede ser tan grave como el externo. La carencia de monitoreo y de políticas de mínimo privilegio fue determinante.

Elemento	**Respuesta**
Servicios X.800 comprometidos.	Confidencialidad de Datos, Control de Acceso.
Definición(es) aplicable(s) RFC 4949.	• Access control: Proceso mediante el cual el uso de los recursos del sistema se regula de acuerdo con una política de seguridad y solo lo permiten las entidades autorizadas (usuarios, programas, procesos u otros sistemas) de acuerdo con dicha política.
Tipo de amenaza	Interna (Empleado con acceso legítimo).
Vector de ataque	Uso indebido de credenciales y privilegios autorizados para la extracción de información.
Impacto técnico / operativo.	Pérdida de confidencialidad de datos críticos, Riesgo legal y regulatorio, Impacto financiero.
Medida de control recomendada.	Política de mínimo privilegio, Monitoreo de actividades de usuarios privilegiados, Auditorías periódicas de accesos.

Escenario 07.

Tras un ataque, los registros del sistema quedaron cifrados o alterados, impidiendo reconstruir la secuencia de eventos. Esto compromete la integridad de los datos y el no repudio, ya que no es posible demostrar qué ocurrió ni quién fue responsable. Desde el RFC 4949, se trata de una violación de evidentiary integrity y del audit trail. El impacto no solo es técnico, sino también probatorio y legal.

Elemento	Respuesta
Servicios X.800 comprometidos.	Confidencialidad de datos, Control de acceso, Integridad de Datos, No Repudio.
Definición(es) aplicable(s) RFC 4949.	• Integrity: Propiedad que asegura que los datos no sean modificados de manera no autorizada. • Non-repudiation Service: Servicio que proporciona prueba de la participación de una entidad en una acción, evitando que esta pueda negarla posteriormente. • Attack: Un acto intencional mediante el cual una entidad intenta evadir los servicios de seguridad y violar la política de seguridad de un sistema.
Tipo de amenaza	Externo (actor malicioso).
Vector de ataque	Alteración o cifrado de registros del sistema durante o después del ataque principal.
Impacto técnico / operativo.	Debilitamiento de controles de cumplimiento normativo, Acceso persistente no autorizado, Riesgo reputacional y legal.
Medida de control recomendada.	entralización de logs en sistemas seguros (SIEM), Monitoreo continuo y respaldo seguro de información de auditoría.

Escenario 08.

Una actualización mal ejecutada provocó la caída simultánea de múltiples servicios críticos a nivel global. Aunque no existió un atacante, el servicio de disponibilidad fue gravemente afectado. El RFC 4949 contempla estos eventos como operational failure, recordando que la seguridad también se ve afectada por errores internos. La falta de pruebas previas y planes de reversión amplificó el impacto.

Elemento	Respuesta
Servicios X.800 comprometidos.	Disponibilidad
Definición(es) aplicable(s) RFC 4949.	• Availability: La propiedad de un sistema o un recurso del sistema de ser accesible, utilizable u operativo bajo demanda.
Tipo de amenaza	Interna (no intencional)
Vector de ataque	Actualización de software defectuosa sin pruebas previas ni mecanismos de reversión.
Impacto técnico / operativo.	Caída simultánea de servicios críticos a nivel global, Interrupción de operaciones esenciales, Impacto reputacional y pérdida de confianza de clientes.
Medida de control recomendada.	Pruebas previas en entornos de staging, Planes de reversión (rollback), Gestión de cambios formal (Change Management).

Escenario 09.

Atacantes replicaron sitios y correos oficiales para engañar a ciudadanos y obtener información sensible. Este escenario afecta la autenticación, al suplantar identidades legítimas, y la confidencialidad de los datos recolectados. El RFC 4949 lo clasifica como masquerade y phishing, subrayando el componente de ingeniería social. La ausencia de mecanismos de autenticación del dominio y de concientización facilitó el éxito del ataque.

Elemento	Respuesta
Servicios X.800 comprometidos.	Autenticación, Confidencialidad de Datos.
Definición(es) aplicable(s) RFC 4949.	• Masquerade: Un tipo de acción de amenaza mediante la cual una entidad no autorizada obtiene acceso a un sistema o realiza un acto malicioso haciéndose pasar ilegítimamente por una entidad autorizada. • Phishing: Una técnica para intentar obtener datos confidenciales, como números de cuentas bancarias, mediante una solicitud fraudulenta por correo electrónico o en un sitio web, en la que el autor se hace pasar por una empresa legítima o una persona de buena reputación. • Authentication: El proceso de verificar una afirmación de que una entidad del sistema o un recurso del sistema tiene un valor de atributo determinado.
Tipo de amenaza	Externa (Ejecutada por atacantes que replicaron sitios y correos oficiales para engañar a ciudadanos).

Vector de ataque	Sitios web falsificados y correos electrónicos fraudulentos que imitan entidades legítimas.
Impacto técnico / operativo.	Pérdida de confidencialidad de datos personales y financieros, Daño reputacional, Impacto Social.
Medida de control recomendada.	Autenticación de dominios (SPF), Certificados digitales y HTTPS obligatorios, Implementación de MFA.

Escenario 10.

En algunos incidentes, tras exfiltrar información, los atacantes ejecutaron acciones destructivas para borrar sistemas completos y eliminar rastros. Se produce un compromiso total de la confidencialidad, la integridad y la disponibilidad, configurando uno de los peores escenarios posibles. El RFC 4949 describe este patrón como destructive attack, donde el objetivo no es solo el lucro, sino el daño irreversible. La detección tardía impidió cualquier contención efectiva.

Elemento	Respuesta
Servicios X.800 comprometidos.	Confidencialidad de Datos, Integridad de Datos, Disponibilidad
Definición(es) aplicable(s) RFC 4949.	• Availability: La propiedad de un sistema o un recurso del sistema de ser accesible, utilizable u operativo bajo demanda. • Attack: Un acto intencional mediante el cual una entidad.intenta evadir los servicios de seguridad y violar la política de seguridad de un sistema.
Tipo de amenaza	Externa (Ejecutada por atacantes con intención deliberada de maximizar el daño)
Vector de ataque	Exfiltración inicial de información sensible, Uso de malware avanzado o acceso privilegiado prolongado.
Impacto técnico / operativo.	Compromiso total de la tríada CIA, Pérdida catastrófica de datos y sistemas, Interrupción operativa crítica y prolongada, Daño reputacional y financiero severo.
Medida de control recomendada.	Respaldos offline e inmutables, Segmentación de red y privilegios mínimos, Plan de respuesta a incidentes y continuidad de negocio.

Conclusión

El análisis de incidentes de seguridad informática mediante los marcos ITU-T X.800 y RFC 4949 permite identificar de manera clara los servicios de seguridad comprometidos y describir técnicamente las vulneraciones detectadas. Su uso conjunto proporciona una base sólida para evaluar incidentes de forma estructurada y consistente.

En el entorno latinoamericano, donde persisten debilidades en la implementación de controles de seguridad y en la cultura organizacional, la adopción de estos estándares representa una oportunidad para mejorar la gestión de la seguridad de la información. La aplicación de políticas básicas, controles de acceso adecuados y procesos de capacitación continua contribuye a reducir riesgos y fortalecer la protección de los activos digitales.

En conclusión, el uso de marcos estandarizados como ITU-T X.800 y RFC 4949 favorece una documentación técnica clara, una mejor comunicación profesional y la implementación de estrategias de seguridad más efectivas, alineadas con las necesidades actuales de la región.

Referencias

RFC 4949: Internet Security Glossary, Version 2. (s. f.). IETF Datatracker. https://datatracker.ietf.org/doc/html/rfc4949#ref-FP191